

Tri Thức Bảo Mật Thích Ứng Đối Phó Với Các Chiến Dịch Lây Nhiễm Mã Độc

Phan Thế Duy*, Phòng thí nghiệm An toàn thông tin (InSecLab),
Trường ĐH Công nghệ Thông Tin - ĐHQG Tp. HCM

Ngày 9 tháng 7 năm 2024



Phòng thí nghiệm An toàn thông tin: Giới thiệu chung

Giới thiệu chung về PTN ATTT

- Thông tin chung: Phòng thí nghiệm An toàn thông tin (UIT InSecLab), là PTN chuyên thực hiện các nghiên cứu khoa học về lĩnh vực An toàn thông tin
 - Được thành lập 19/01/2016, là 01 trong 03 PTN cấp trường được đầu tư tại UIT.
 - Là PTN duy nhất chuyên về lĩnh vực An toàn thông tin trong hệ thống ĐHQG-HCM.
- Mục tiêu:
 - Thực hiện các nhiệm vụ NCKH liên quan đến an toàn thông tin
 - Thực hiện tư vấn, nghiên cứu giải pháp và chuyển giao công nghệ nhằm giải quyết vấn đề kỹ thuật, công nghệ cụ thể có liên quan đến ATTT do địa phương, doanh nghiệp đặt hàng;
- Website: <https://inseclab.uit.edu.vn/>
- Email: inseclab@uit.edu.vn
- Fanpage: <https://www.facebook.com/inseclab>

Nhân sự nghiên cứu chính



TS. Phạm Văn Hậu
Trưởng PTN ATTT



ThS. Phan Thế Duy
Nghiên cứu viên

Nhân sự nghiên cứu chính



ThS. Đỗ Thị Thu Hiền
Nghiên cứu viên



ThS. Đỗ Hoàng Hiến
Nghiên cứu viên



ThS. Nghi Hoàng Khoa
Nghiên cứu viên



ThS. Ngô Khánh Khoa
Nghiên cứu viên



KS. Đoàn Minh Trung
Nghiên cứu viên



CN. Nguyễn Hữu Quyền
Nghiên cứu viên



KS. Tô Trọng Nghĩa
Nghiên cứu viên



KS. Ngô Đức Hoàng Sơn
Nghiên cứu viên

Nhân sự nghiên cứu chính



TS. Nguyễn Tấn Cầm
Giảng viên, Cộng tác viên



ThS. Trần Tuấn Dũng
Giảng viên, Cộng tác viên

Thông tin liên hệ

- Email: duypt@uit.edu.vn
- Telegram: [phantheduyy](https://t.me/phantheduyy)



Chuỗi tiêu diệt (Kill Chain): Nguồn gốc

“Kill chain” is the colloquial name for a concept that originated within the United States military to model the sequential steps that must be conducted in order to successfully plan and deliver an attack and deliver a “kill” (delivery of the objective and destruction of a target).

- Chuỗi tiêu diệt (Kill Chain) là khái niệm được quân đội Hoa Kỳ đề xuất nhằm mô hình các bước liên tiếp cần phải thực hiện để **lập kế hoạch và thực hiện một cuộc tấn công và phân phối một đối tượng tới mục tiêu** (thả đối tượng tới mục tiêu và phá hủy mục tiêu) .
- Khởi nguồn vào cuối thập niên 1990 với khái niệm **"Find, Fix, Track, Target" (FFTT)**, và sau đó mở rộng thành **"Find, Fix, Track, Target, Engagement, Assessment" (F2T2EA)** với giả định một cuộc tấn công sẽ không kết thúc mà là sự khởi đầu kéo theo các giai đoạn linh hoạt phía sau.

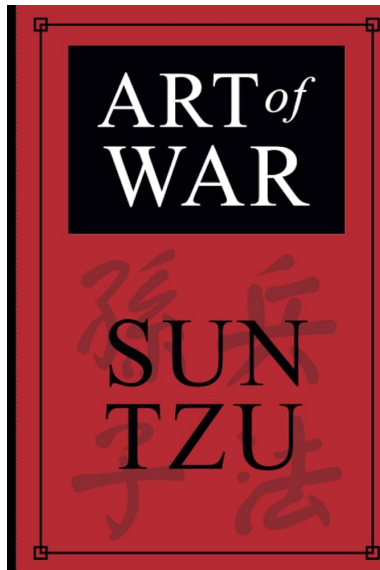
Chuỗi tiêu diệt (Kill Chain): Tầm quan trọng của việc hiểu mô hình khái niệm về tấn công

An ninh mạng là một lĩnh vực tương đối mới so với nhiều ngành khoa học lâu đời khác, đặc biệt là đối với học thuyết quân sự

- Binh pháp Tôn Tử (Tôn Vũ - Trung Quốc): nổi tiếng có niên đại từ thế kỷ thứ 5 trước Công nguyên (thời Xuân Thu)
- Có thể rút ra những điểm tương đồng về mặt khái niệm giữa lĩnh vực an ninh mạng và các lĩnh vực khác (bao gồm học thuyết quân sự).
- Phần lớn thuật ngữ và thực tiễn áp dụng về an ninh mạng được mô hình hóa dựa trên các khái niệm từ các lĩnh vực khác, bao gồm quân sự: phòng thủ theo chiều sâu (defense in depth), tấn công (Attack), gia cố (hardening), mối đe dọa (threat), xâm nhập (penetration), bề mặt tấn công (attack surface),...



Nghệ thuật chiến tranh: Binh Pháp Tôn Tử



Cyber Kill Chain: Tổng quan (1)

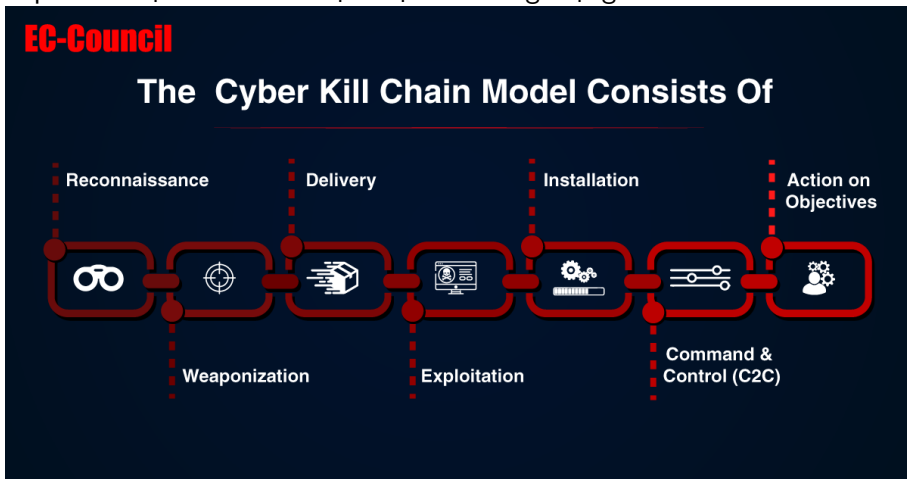
Chuỗi tiêu diệt không gian mạng (Cyber kill chain) là mô hình tái hiện chuỗi hành động gồm 7 bước liên tiếp để tin tặc triển khai một cuộc tấn công mạng.

Khái niệm “Chuỗi tiêu diệt không gian mạng” lần đầu tiên được Lockheed Martin công bố chính thức dưới dạng mô hình như một phần của phương pháp “Phòng thủ dựa trên tri thức” (Intelligence Driven Defense) của họ.

- Lockheed Martin là một công ty an ninh và hàng không vũ trụ của Hoa Kỳ với các đơn vị kinh doanh trải rộng trên mọi lĩnh vực, từ hàng không đến vệ tinh và tên lửa chiến lược cũng như các giải pháp phòng thủ mạng.
- Lockheed Martin có lẽ là tổ chức có vị thế đặc biệt để chuyển một số mô hình và khái niệm có trong cộng đồng phòng thủ và chiến tranh truyền thống sang chiến tranh phi truyền thống - an ninh mạng.

Cyber Kill Chain: Tổng quan (2)

Chuỗi tiêu diệt không gian mạng (Cyber kill chain) là mô hình tái hiện chuỗi hành động gồm 7 bước liên tiếp để tin tặc triển khai một cuộc tấn công mạng.



Cyber Kill Chain vs. MITRE ATT&CK

Khung MITRE ATT&CK rất hữu ích để hiểu hành vi của các tác nhân đe dọa thông qua việc ghi lại các kỹ thuật, chiến thuật, công cụ được sử dụng trong các cuộc tấn công trước đó.

CYBER KILL CHAIN vs. MITRE ATT&CK

CYBER KILL CHAIN

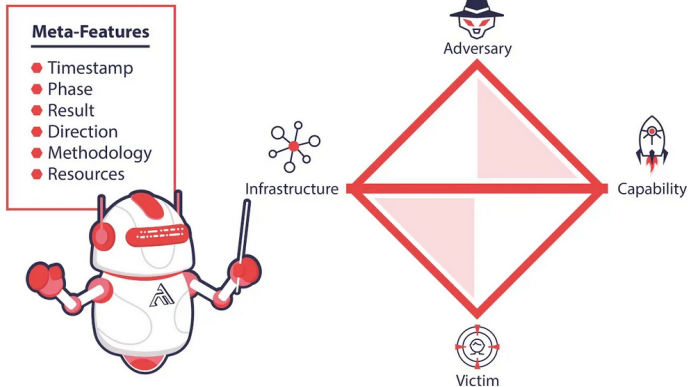
- Reconnaissance
- Weaponization
- Delivery
- Exploitation
- Installation
- Command & Control
- Actions on Objectives



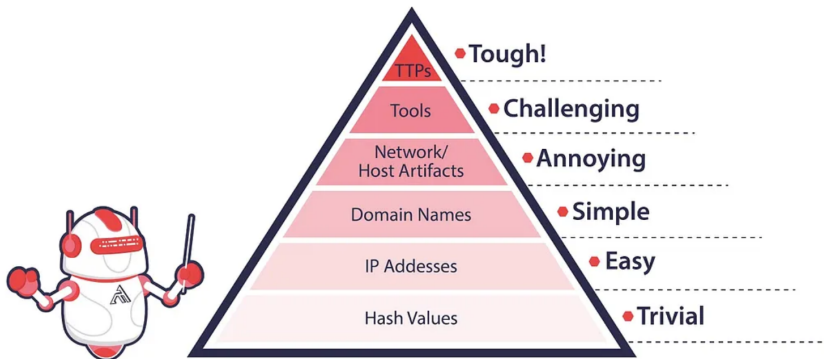
MITRE ATT&CK

- Initial Access
- Execution
- Persistence
- Privilege Escalation
- Defence Evasion
- Credential Access
- Discovery
- Lateral Movement
- Collection
- Exfiltration
- Command and Control
- Impact

THE DIAMOND MODEL



PYRAMID OF PAIN



Chiến lược phòng thủ: Thế nào là khôn ngoan?

Conventional Wisdom in Defense



Traditional Defenders

- Defend a list of assets
- Manage incidents
- Minimize risks by keeping incidents secret
- View pentest results as a report card
- Think about stopping attacks



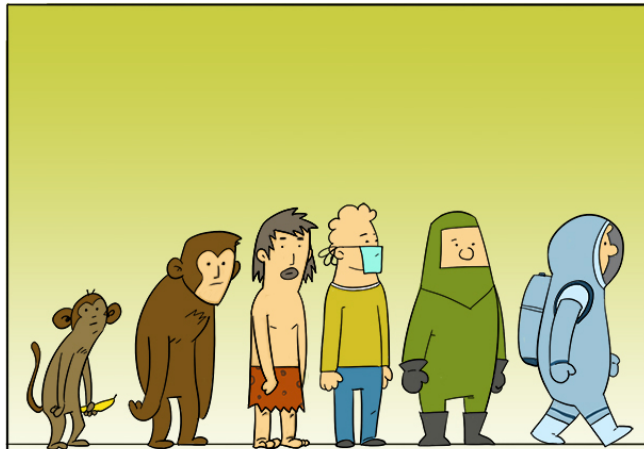
Modern Defenders

- Defend a graph of assets
- Manage adversaries
- Maximize learning by sharing incidents with trusted outside peers
- View pentest results as an input
- They think about increasing attacker requirements

Thuyết tiến hóa Darwin trong An toàn thông tin

Darwinism in IT Security: Adapt or Die.

“IT IS NOT THE STRONGEST OF THE SPECIES THAT SURVIVES BUT THE MOST ADAPTABLE TO CHANGE.” – CHARLES DARWIN



Tốc độ của sự thay đổi trong lĩnh vực An toàn thông tin

Sự khác biệt duy nhất của quá trình thay đổi của các mối đe dọa bảo mật khi so với quá trình tiến hóa sinh học của Darwin **là tốc độ thay đổi** - không phải hàng thiên niên kỷ ở đây mà **chỉ vài tháng** đối với nhiều thể hệ mối đe dọa tiến hóa.

- Để tạo ra một hệ thống bảo mật ưu việt cung cấp khả năng bảo vệ lý tưởng (tối đa), ngay từ đầu, các nhà phát triển cần phải hình dung ra tình huống xấu nhất trong số các tình huống nguy hiểm nhất có thể xảy ra.
- *Ngược lại với quá trình tiến hóa sinh học, những thay đổi trong Bảo mật CNTT nhanh hơn... một chiếc Ferrari (In contrast to biological evolution, changes in IT Security are faster than... a Ferrari).*
- **Nếu bạn biết điểm yếu của mình, bạn không còn là mục tiêu bị săn, bây giờ bạn chính là người đi săn (If you know your weakness, you're no longer the hunted; you're the hunter).**

Tri thức bảo mật thích ứng (Adaptive Cybersecurity Intelligence)

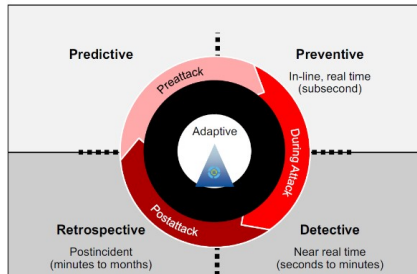
Tri thức Bảo mật thích ứng (Adaptive Cybersecurity Intelligence) là một phương pháp an ninh mạng linh động, tận dụng khả năng giám sát liên tục, trí thông minh/tri thức theo thời gian thực và học máy để dự đoán và ứng phó một cách hiệu quả trước các mối đe dọa mạng liên tục gia tăng và biến đổi.



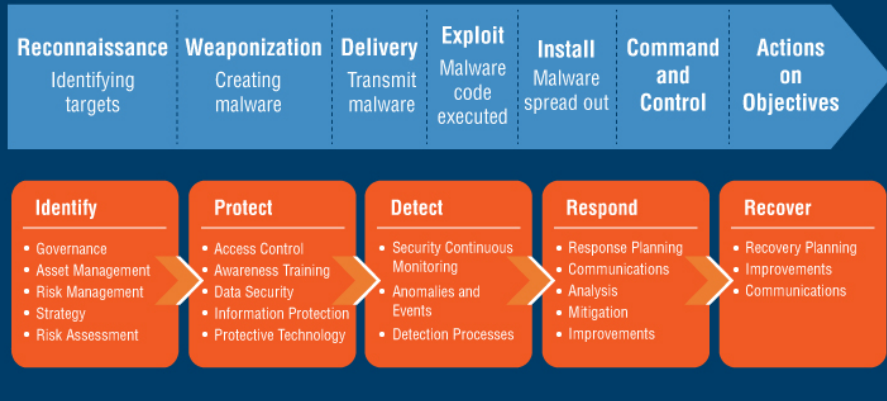
Mô hình bảo mật thích ứng: Thích nghi hay là Chết?

Mô hình bảo mật thích ứng (Adaptive Cybersecurity Model) được giới thiệu bởi Gartner vào năm 2014.

- Kiến trúc này dựa trên việc áp dụng theo chu kỳ các công cụ từ bốn lĩnh vực cơ bản liên quan đến tấn công mạng: phòng ngừa (preventive), điều tra (detective), ứng cứu (retrospective) và dự đoán (predictive).
- Việc áp dụng mô hình thích ứng cho phép tạo ra sự bảo vệ tối ưu tương ứng với vòng đời của các cuộc tấn công mạng – một mô hình có thể nhanh chóng tự điều chỉnh để thay đổi các điều kiện bên trong và bên ngoài.

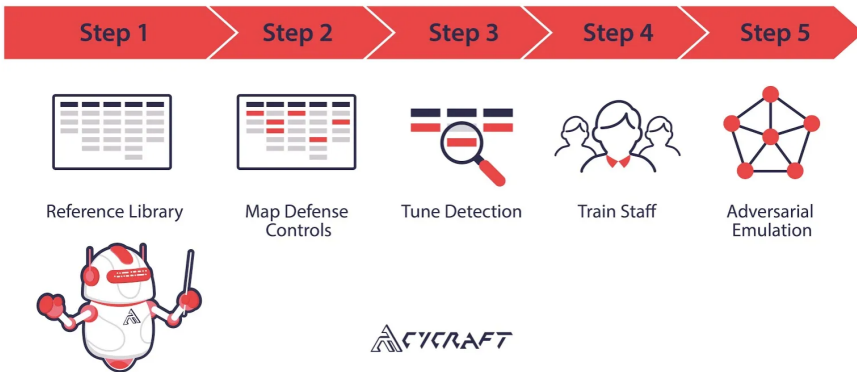


Cyber Kill Chain and Defensive Approach



MITRE ATT&CK và Phương pháp Phòng thủ

HOW TO IMPLEMENT THE MITRE ATT&CK FRAMEWORK INTO YOUR DEFENSE



Tổng kết I

Xin cảm ơn!